

CYBERSECURITY PORTFOLIO

Identity & Access Management Role-Based Access Control Assessment

Northstar Financial Group

Fictional Organizational Security Assessment | Portfolio Simulation

Analyst	Ryan Bryant
Organization	Northstar Financial Group (fictional)
Project focus	IAM, RBAC, least privilege, PAM, SoD, JML, service accounts
Deliverable	Target-state RBAC design and implementation roadmap

This report documents a fictional portfolio simulation. No real client, production environment, or live employee data is represented.

1. Executive Summary

Northstar Financial Group previously identified access-control weaknesses including privilege creep, inconsistent role changes, broad Finance access, executive MFA exceptions, and weak service-account governance. This project translates those risks into a target-state Identity and Access Management (IAM) and Role-Based Access Control (RBAC) design for a 75-employee financial-services organization.

The design assigns access according to documented job responsibilities, separates business approval from technical provisioning, isolates privileged administrator identities from everyday accounts, enforces separation of duties for financial transactions, provides auditors with read-only evidence access, and treats non-human service identities as governed security principals rather than convenience accounts.

Target-state outcome

Northstar should be able to answer three questions for every identity: Who is this identity? What business role does it serve? Why does it have each permission? Access that cannot be justified by an active business requirement should not remain assigned.

Project Objectives

- Define a consistent permission model and role-based entitlement structure.
- Apply least privilege to business, technical, executive, audit, and service identities.
- Prevent privilege creep through event-driven Joiner/Mover/Leaver controls.
- Separate payment creation, approval, access authorization, provisioning, auditing, and administration duties.
- Limit permanent privileged access and introduce separate administrator identities and Just-in-Time containment rights.
- Create a consolidated RBAC matrix that can serve as the target-state access baseline.

Scope and Assumptions

Organization	Northstar Financial Group; fictional 75-employee financial-services firm.
Identity platform	Active Directory / Microsoft Entra ID.
Business platforms	Microsoft 365, Customer CRM, Finance repository, Payroll SaaS, HRIS, Vendor portal, Accounts Payable system.
Technical platforms	VPN, IT administration tools, backup administration, security platform.
Assessment method	Role-by-role access decisions based on stated job duties, least privilege, separation of duties, and business need.
Limitations	No live tenant configuration, production entitlement export, or technical enforcement test was performed.

2. Permission Model and Design Rules

Code	Meaning	Use in this project
N	No Access	No standing entitlement.
U	Standard User	Authentication or normal end-user access.

Code	Meaning	Use in this project
R	Read Only	View records or evidence without modification.
RW	Read / Write	Create or update business records within role scope.
A	Approve / Authorize	Approve business actions without administering the platform.
ADM	Administrative	Scoped technical administration of an application or service.
PA	Privileged Administrative	High-impact administrative authority over identities or infrastructure.
SR	Scoped Read	Read limited data or fields required for a specific role/audit.
SRW	Scoped Read / Write	Modify only a defined subset of records or fields.
JIT	Just-in-Time	Temporary elevated privilege activated under an approved workflow.

IAM Design Principles Established

Payment Creator != Payment Approver: Accounts Payable can prepare transactions but cannot approve its own transactions.

Business Approver != Technical Provisioner: Managers authorize business need; IT/IAM implements the approved entitlement.

Standard Account != Privileged Admin Account: Systems administrators use separate identities for daily work and high-impact administration.

Investigative Access != Permanent Admin Access: Security analysts receive broad visibility but temporary/scoped containment rights.

Executive Authority != Technical Administration: Executive seniority does not create a need for administrative platform privileges.

Information Need != Direct System Access: Executives may receive reports or dashboards instead of raw system access.

Auditor Access != Operational Modification Rights: Compliance staff can verify evidence without changing the evidence being audited.

Service Function != Domain Administration: Service identities receive only permissions required for their automated function.

New Role != Old Role + New Permissions: Mover events replace obsolete access rather than accumulating privileges.

3. Consolidated Target-State RBAC Matrix

Composite values such as RW+A indicate combined business permissions. SR/SRW are scoped permissions; AUTH means authentication only. Temporary audit access and incident-response JIT elevation are intentionally excluded from standing entitlements. Executive security information is delivered through controlled reporting rather than direct SIEM access.

System	Emily Financial Analyst	Michael Finance Manager	Samantha A/P Specialist	Jennifer HR Manager	Daniel Standard	Daniel Admin	Alex Security Analyst	Robert CEO	Amanda Compliance	svc-backup-nfg Service	Emily HR Comp Analyst
IAM-01 AD / Entra ID	U	U	U	U	U	PA	SR	U	U+SR	AUTH	U
IAM-02 Microsoft 365	RW	RW	RW	RW	RW	ADM	SR	RW	RW	N	RW
IAM-03 Customer CRM	R	RW+A	N	N	N	N	N	R+A	N	N	N
IAM-04 Finance File Repository	RW	RW+A	RW	N	N	N	N	R	SR	SR	N
IAM-05 Payroll SaaS	N	SR	N	R+A	N	N	N	N	N	N	SR
IAM-06 HRIS	N	N	N	RW+A	N	N	N	N	SR	N	SRW
IAM-07 VPN	U	U	U	U	U	ADM	R	U	U+R	N	U
IAM-08 IT Admin Tools	N	N	N	N	N	PA	ADM	N	SR	N	N
IAM-09 Backup Admin	N	N	N	N	N	ADM	R	N	R	SRW	N
IAM-10 Security Platform	N	N	N	N	R	R	ADM	N	R	N	N
IAM-11 Vendor Portal	N	N	RW	N	N	N	N	R+A	R	N	N
IAM-12 Executive Financial Repository	N	SR	N	N	N	N	N	R	SR	SR	N
IAM-13 Accounts Payable System	N	A	RW	N	N	N	N	A	SR	N	N

4. Role Profiles and Access Rationale

Emily Carter - Financial Analyst

Target permissions: U | RW | R | RW | N | N | U | N | N | N | N | N | N

Needs customer information, Finance working files, collaboration tools, and remote access. No payroll, HR, administrative, security, vendor, executive, or payment-system access.

Michael Torres - Finance Manager

Target permissions: U | RW | RW+A | RW+A | SR | N | U | N | N | N | N | SR | A

Can manage and approve Finance work and approve Accounts Payable transactions. Payroll and executive data are limited to departmental summaries; he can authorize business access requests but cannot provision them.

Samantha Reed - Accounts Payable Specialist

Target permissions: U | RW | N | RW | N | N | U | N | N | N | RW | N | RW

Can prepare vendor payments and maintain vendor records but cannot approve or release a payment she created.

Jennifer Walsh - HR Manager

Target permissions: U | RW | N | N | R+A | RW+A | U | N | N | N | N | N | N

Owns HR workflows and authorizes employment/compensation changes. HR initiates identity lifecycle events; IT/IAM performs account provisioning and disablement.

Daniel Kim - Standard Account

Target permissions: U | RW | N | N | N | N | U | N | N | R | N | N | N

Used for email, collaboration, remote access, and limited troubleshooting. Carries no infrastructure administration privileges.

Daniel Kim - Privileged Administrator Account

Target permissions: PA | ADM | N | N | N | N | ADM | PA | ADM | R | N | N | N

Separate non-daily identity for authorized identity, endpoint/server, VPN, and backup administration. No email, general web use, or business-system access.

Alex Morgan - Cybersecurity Analyst

Target permissions: SR | SR | N | N | N | N | R | scoped ADM | R | ADM | N | N | N

Receives broad investigative visibility and administration of the security platform. High-impact AD/VPN containment is activated temporarily under the Incident Response SOP.

Robert Hayes - CEO

Target permissions: U | RW | R+A | R | N | N | U | N | N | executive reporting | R+A | R | scoped A

Receives business information and approval authority without technical administration. Cybersecurity, backup, payroll, and HR information is delivered through controlled reporting where direct system access is unnecessary.

Amanda Brooks - Compliance & Risk Manager

Target permissions: U+SR | RW | audit SR as needed | SR | audit SR as needed | SR | U+R | SR | R | R | R | SR | SR

Maintains read-only audit visibility while preserving independence and evidence integrity. Sensitive systems not needed routinely are accessed only under an approved audit scope.

svc-backup-nfg - Backup Service Account

Target permissions: AUTH | N | N | SR | N | N | N | service-only if required | SRW | N | N | scoped backup read | N

Non-human identity limited to reading approved backup sources and writing backup data. No interactive logon, email, VPN, Domain Admin, or unrelated business access.

Emily Carter - HR Compensation Analyst (Mover Target)

Target permissions: U | RW | N | N | SR | SRW | U | N | N | N | N | N | N

Finance and CRM access are removed at the role-change effective time. New access is limited to compensation-related payroll visibility and HRIS records.

5. Separation of Duties and Privileged Access Management

Financial Transaction Separation

Samantha can create and prepare Accounts Payable transactions, while Michael or another designated approver must independently review and authorize release. The application should technically prevent a transaction creator from approving the same transaction.

Control objective

Prevent one compromised or malicious account from both creating and approving a high-value payment.

Business Approval vs. Technical Provisioning

Managers determine whether a business need exists; HR confirms employment status and role changes; IT/IAM implements approved entitlements. No manager receives directory administration merely because the manager can approve a business access request.

Separate Administrator Identities

- Daily user accounts are used for email, collaboration, browsing, and routine work.
- Privileged accounts are used only for authorized administrative tasks and have separate credentials.
- Privileged identities have stronger authentication, shorter sessions, detailed logging, and periodic review.
- Privileged accounts should not have normal mailboxes, Teams, or routine web-browsing use.

Just-in-Time Incident Response Access

Cybersecurity analysts should not retain permanent Domain Admin or equivalent high-impact rights. When an incident meets documented containment criteria, a dedicated incident-response role can temporarily grant scoped authority to disable an identity, revoke sessions, restrict VPN access, or isolate an endpoint. The elevated role should expire automatically and every action should be tied to an incident record.

6. Joiner / Mover / Leaver (JML) Procedure

Joiner

1. HR creates the authoritative hire event and effective start date.
2. The hiring manager selects an approved business role; exceptions require documented justification.
3. IT/IAM provisions the identity through role-based groups rather than ad hoc individual permissions.
4. MFA is enrolled before access to sensitive resources is enabled.
5. The manager verifies that required access works and IT records completion.

Mover

6. HR records the new role and exact effective time.
7. Old-role access is reviewed and removed before or concurrently with new-role access.
8. New manager approves only the entitlements required for the new role.
9. IT/IAM implements the entitlement replacement and verifies both positive access and removal of obsolete access.
10. The mover event is logged for the next formal access review.

Mover rule

New Role Access != Old Role Access + New Permissions. A role change triggers an immediate authorization review; quarterly audits are a safety net, not a substitute for event-driven deprovisioning.

Leaver

11. HR provides the effective separation time and urgency level.
12. IT/IAM disables sign-in at the effective time, revokes active sessions/tokens, and removes VPN access.
13. Privileged accounts and service-account ownership assignments are reviewed immediately.
14. Company devices and removable media are recovered; business data ownership is transferred as required.
15. The account may be retained for legal/records purposes, but interactive access remains disabled.
16. IT/IAM documents completion and the manager confirms access has been removed.

7. Service Account Governance

The backup service identity is treated as a governed non-human principal. Administrative convenience is not sufficient justification for Domain Admin or broad enterprise access.

Control	Target-state requirement
Purpose and owner	Document business purpose, technical owner, and data sources included in backup scope.
Authentication	Prefer managed service identity/gMSA or centrally managed secrets over static human-maintained passwords.
Credential rotation	Automate rotation where possible; immediately rotate after suspected exposure.
Interactive logon	Deny interactive desktop/remote logon unless a documented technical requirement exists.
Privilege	Read approved sources, write designated backup repositories, and execute backup jobs - no Domain Admin.

Control	Target-state requirement
Network scope	Restrict where the service can authenticate from and which systems accept the identity.
Monitoring	Log authentication, failed access, privilege changes, and abnormal source hosts.
Review	Review at least quarterly and whenever backup scope or ownership changes.

8. MFA, Access Reviews, and Auditability

MFA Policy

- MFA is mandatory for eligible human identities; executive seniority does not qualify for an exception.
- High-value users such as executives and privileged administrators should use phishing-resistant authentication where supported.
- Authentication friction should be reduced through better authentication design, trusted-device controls, and sensible session policy - not by removing MFA.
- Non-human service identities use managed noninteractive authentication and credential rotation rather than human push-based MFA.

Access Review Cadence

Population	Review cadence	Review focus
Privileged administrators	Quarterly and on role change	Standing admin roles, unused entitlements, separate-account controls, MFA.
Sensitive business roles	Quarterly	Finance, HR, executive, vendor, and payment access; separation of duties.
Security / audit roles	Quarterly	Scope of investigative and audit visibility; temporary elevation history.
Service accounts	Quarterly and on scope change	Purpose, owner, secret rotation, source restrictions, privilege.
All users	At least quarterly management certification + event-driven JML	Role accuracy, inactive users, stale groups, privilege creep.

9. IAM Risk Findings and Target Controls

ID	Finding	Risk	Business / security impact	Target control
IAM-R01	Privilege creep during role changes	High	Employees can retain obsolete access after transfers or promotions.	Event-driven Mover review; remove old-role groups at the effective time.
IAM-R02	Executive MFA exceptions	Critical	Compromise of a high-authority executive identity could enable fraud and sensitive-data exposure.	Mandatory MFA; prefer phishing-resistant methods; no seniority-based exceptions.

ID	Finding	Risk	Business / security impact	Target control
IAM-R03	Daily-use accounts carrying admin rights	Critical	Phishing or normal workstation compromise can immediately expose infrastructure-level privilege.	Separate standard and privileged identities; restrict privileged-account use.
IAM-R04	Insufficient payment separation of duties	High	One account could create and approve a fraudulent payment.	Creator/approver technical separation and approval logging.
IAM-R05	Permanent security-analyst containment rights	High	Broad standing admin access increases blast radius if the analyst account is compromised.	JIT incident-response elevation under SOP and automatic expiry.
IAM-R06	Auditors able to modify audit evidence	High	Audit independence and evidence integrity can be undermined.	Scoped read-only auditor roles; temporary audit access packages.
IAM-R07	Overprivileged/static service accounts	Critical	A stolen long-lived credential could provide enterprise-level access.	Managed credentials, no Domain Admin, deny interactive logon, scope authentication.
IAM-R08	Delayed leaver deprovisioning	High	Former employees may retain valid sessions or access after separation.	Time-bound disablement, session/token revocation, VPN removal, completion evidence.
IAM-R09	Broad direct data access where reports would suffice	High	Executives or auditors may gain unnecessary exposure to sensitive records.	Use scoped roles, reports, and dashboards rather than unrestricted application access.

10. 90-Day IAM Implementation Roadmap

Period	Priority actions	Expected outcome
Days 0-30	Approve RBAC naming/ownership model; inventory users/groups/service accounts; enforce MFA; remove known executive exceptions; create separate privileged identities; correct high-risk Finance and HR access.	Immediate reduction of standing privilege and clear ownership of high-risk entitlements.
Days 31-60	Implement Joiner/Mover/Leaver workflow; enforce payment separation of duties; create read-only auditor role; create service-account standards; begin credential rotation and source restrictions; define JIT incident-response elevation.	Role changes stop accumulating privileges and privileged/non-human access becomes governed.
Days 61-90	Run first formal access certification; validate role groups; test urgent termination and JIT containment workflows; review privileged logs; document exceptions; measure completion and revocation times.	Evidence that the IAM design is operating as intended and exceptions are visible to management.

Suggested RBAC Group Naming

- NFG-FIN-ANALYST - standard Financial Analyst entitlements.
- NFG-FIN-MGR-APPROVER - Finance Manager approval entitlements.
- NFG-AP-CREATOR - Accounts Payable create/prepare permissions.
- NFG-AP-APPROVER - payment approval role; mutually exclusive with creator where practical.
- NFG-HR-MGR - HR management and HRIS approval permissions.
- NFG-HR-COMP - compensation analyst scoped payroll/HRIS access.
- NFG-SEC-ANALYST - standing investigative/security platform role.
- NFG-IR-JIT - temporary incident containment permissions.
- NFG-COMPLIANCE-AUDITOR - scoped read-only audit permissions.
- NFG-ADM-SYS - privileged system-administration role for separate administrator identities.

11. Portfolio Value and Employer-Facing Summary

This simulation demonstrates the ability to move from an organizational risk finding to a practical access-control design. The analyst evaluated business duties, challenged unnecessary privileges, separated approval from administration, created target-state role definitions, designed privileged-access and service-account controls, and documented lifecycle processes that prevent stale entitlements.

Portfolio-ready resume bullet

Designed a fictional 75-user IAM/RBAC target state covering 13 enterprise systems; built role-based permissions, separation-of-duties controls, privileged/JIT access, service-account governance, and Joiner/Mover/Leaver procedures to reduce privilege creep and excessive standing access.

Skills Demonstrated

- Identity and Access Management (IAM)

- Role-Based Access Control (RBAC)
- Least privilege
- Separation of duties
- Privileged Access Management (PAM)
- Just-in-Time access
- Joiner/Mover/Leaver lifecycle governance
- Service-account governance
- MFA policy design
- Access certification and auditability
- Risk-based security decision making
- Stakeholder communication

Interview Talking Points

- Why a manager can approve business access without receiving Active Directory administration rights.
- How creator/approver separation reduces fraud risk in Accounts Payable.
- Why security analysts need broad visibility but should not retain permanent Domain Admin privileges.
- How separate standard and privileged administrator identities reduce blast radius from phishing.
- Why auditor access is read-only and sometimes temporary/scoped to preserve evidence integrity.
- How the Mover process removes old permissions at the effective time instead of waiting for quarterly review.
- Why non-human service accounts require credential lifecycle controls even when traditional MFA is impractical.

Analyst Participation and Simulation Note

The role-permission decisions in this report were developed interactively by Ryan Bryant during a fictional Northstar Financial Group IAM/RBAC exercise. Generative AI assisted with scenario development, technical refinement, documentation structure, and professional wording. The analyst made the initial access decisions, evaluated tradeoffs, and revised permissions after least-privilege and separation-of-duties review. No production systems or real employee accounts were accessed.